

INFORMATION SECURITY MANAGEMENT SYSTEMS

ISO 27001:2022

Comprehensive Implementation Guide

Clauses 4–10 • All 93 Annex A Controls • Documents & Records
Statement of Applicability • Risk Assessment • Certification Roadmap

For ISMS Managers • Process Owners • IT & Security Teams • Auditors

By: Saheed Akinloye, CMSA

Toolbox Management Systems Limited

TABLE OF CONTENTS

1.	Introduction & Purpose of ISO 27001:2022
2.	Key Concepts & Terminology
3.	What Changed from ISO 27001:2013
4.	Clause 4 — Context of the Organisation
5.	Clause 5 — Leadership
6.	Clause 6 — Planning
7.	Clause 7 — Support
8.	Clause 8 — Operation
9.	Clause 9 — Performance Evaluation
10.	Clause 10 — Improvement
11.	Annex A — Organisational Controls (5.1–5.37)
12.	Annex A — People Controls (6.1–6.8)
13.	Annex A — Physical Controls (7.1–7.14)
14.	Annex A — Technological Controls (8.1–8.34)
15.	Master Documents & Records Register
16.	Key ISMS Metrics & KPIs
17.	Certification Roadmap
18.	About Toolbox Management Systems Limited

1. INTRODUCTION & PURPOSE OF ISO 27001:2022

Understanding the Standard and Its Business Value

ISO/IEC 27001:2022 is the internationally recognised standard for Information Security Management Systems (ISMS). It specifies requirements for establishing, implementing, maintaining and continually improving an ISMS — a systematic approach to managing sensitive company information so that it remains secure across people, processes and technology.

Certification to ISO 27001:2022 signals to clients, regulators, partners and the market that your organisation takes information security seriously — and has the documented, audited evidence to prove it. It is the most widely adopted information security standard globally, with over 70,000 certified organisations in more than 150 countries.

Attribute	Detail
Standard	ISO/IEC 27001:2022 (supersedes ISO 27001:2013)
Full Title	Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements
Companion Standard	ISO/IEC 27002:2022 — Guidance on implementing Annex A controls
Structure	High Level Structure (HLS) — compatible with ISO 22301, ISO 9001, ISO 14001 etc.
Annex A Controls	93 controls across 4 themes (reduced from 114 controls in 14 domains)
Transition Deadline	31 October 2025 — all 2013-certified organisations must recertify to 2022
Certification	Third-party accredited certification body — Stage 1 document review + Stage 2 implementation audit
Audit Cycle	Annual surveillance audits; 3-year recertification cycle

Why ISO 27001:2022 matters: In Nigeria, regulators including the **NDPC, CBN, NITDA, NCC and NAICOM** require information security and data protection frameworks. Internationally, **GDPR (EU), UK GDPR, CCPA (US), HIPAA (US), PCI-DSS, SOX** and the **NIS2 Directive** demand demonstrable security controls for sensitive information. ISO 27001:2022 provides the auditable, globally recognised framework that satisfies regulators, clients and supply chain due diligence requirements simultaneously.

2. KEY CONCEPTS & TERMINOLOGY

Essential Definitions Every Implementer Must Know

A shared understanding of core ISMS terminology is essential before implementation begins. Misalignment on these definitions — particularly around risk appetite, SoA scope, and control objectives — is a common cause of audit nonconformities.

Term	Full Form / Meaning
ISMS	Information Security Management System — the overall framework for managing information security
CIA Triad	Confidentiality, Integrity, Availability — the three pillars of information security
SoA	Statement of Applicability — mandatory document listing all 93 Annex A controls with inclusion/exclusion justification
Risk Assessment	Process of identifying, analysing and evaluating IS risks to the organisation
Risk Treatment	Selecting and implementing controls to address identified risks
Risk Owner	Person accountable for managing a specific identified risk
Control	Measure that modifies risk — a policy, procedure, practice, technical safeguard or organisational structure
Residual Risk	Risk remaining after controls have been applied
Risk Appetite	Amount of risk an organisation is prepared to accept in pursuit of its objectives
Asset	Anything of value to the organisation — information, systems, people, premises, services
Threat	Potential cause of an unwanted incident that could harm the organisation or its assets
Vulnerability	Weakness in a system, process or control that could be exploited by a threat
Interested Party	Any stakeholder with a relevant interest in the ISMS — regulators, clients, staff, suppliers
PDCA	Plan-Do-Check-Act — the continual improvement cycle underpinning the ISMS
11 New Controls (2022)	Threat intelligence, ICT readiness for BC, physical security monitoring, configuration management, information deletion, data masking, DLP, monitoring activities, web filtering, secure coding, cloud services use

3. WHAT CHANGED FROM ISO 27001:2013

Key Differences Every Implementer Must Understand

The 2022 revision introduced significant structural and control changes. Organisations certified to the 2013 edition must transition by 31 October 2025. Understanding the changes is essential for both new implementations and transition projects.

Area	ISO 27001:2013	ISO 27001:2022
Annex A Controls	114 controls in 14 domains/clauses	93 controls in 4 themes
Control Themes	14 domain categories	Organisational, People, Physical, Technological
New Controls	—	11 new controls added (see terminology section)
Attributes	Not present	Control attributes for filtering introduced (5 attribute types)
Clause 6.3	Not present	Planning of changes to the ISMS now explicit
Clause 9.3	Single management review clause	Split into 9.3.1 General, 9.3.2 Inputs, 9.3.3 Results
Control Merging	114 individual controls	57 controls merged/consolidated from 2013
Revised Controls	—	58 controls revised with updated guidance

Transition requirement: All organisations certified to ISO 27001:2013 must complete transition to ISO 27001:2022 by **31 October 2025**. Key transition steps: (1) Gap analysis against 2022 Annex A, (2) Update the Statement of Applicability, (3) Address 11 new controls, (4) Update risk assessment if needed, (5) Transition audit with your certification body.

4. CLAUSE 4 — CONTEXT OF THE ORGANISATION

Defining the ISMS Scope and Understanding the Environment

Clause 4 establishes the foundation of the ISMS. The organisation must understand its internal and external environment, identify stakeholders and their IS requirements, define the ISMS scope precisely, and establish the management system. Every subsequent ISMS activity — risk assessment, control selection, auditing — depends on a well-defined scope.

Clause Requirements

- 4.1: Identify internal and external issues relevant to the organisation's purpose that affect its ability to achieve ISMS objectives
- 4.2: Identify interested parties and determine their relevant IS requirements — including contractual, regulatory and legal obligations
- 4.3: Define and document the ISMS scope — boundaries, assets, locations, technologies and interfaces included
- 4.4: Establish, implement, maintain and continually improve the ISMS in accordance with ISO 27001:2022 requirements

Mandatory Documents	Records to Maintain
✓ ISMS Scope Document	✓ Context review session records
✓ Context of the Organisation Analysis	✓ Stakeholder requirement analysis records
✓ Interested Parties Register	✓ Scope approval and sign-off records
✓ Legal & Regulatory Obligations Register	✓ Audit trails for scope amendments
✓ ISMS Policy (supports Clause 5.2)	✓ Regulatory review correspondence

Process Owner & Implementer Actions

- Conduct PESTLE and SWOT analyses to identify internal and external issues; document findings and present to management
- Map all interested parties: employees, customers, regulators, suppliers etc.
- Identify all applicable legal and requirements: GDPR, CCPA, HIPAA, PCI-DSS, NIS2, SOX, DORA etc.
- Define the ISMS scope with precision — include all information assets, systems, locations, third-party interfaces and business processes within scope; document exclusions with clear written justification
- Ensure the scope is formally reviewed and approved by top management at minimum annually and on any significant change
- Directly link scope to the asset inventory (Annex A 5.9) and risk assessment boundary

■ **Practitioner Tip:** Scope is the single most consequential decision in ISMS implementation. Too broad and the programme becomes unmanageable; too narrow and clients and regulators may reject the certification. Document all exclusions explicitly — an auditor will probe every one.

5. CLAUSE 5 — LEADERSHIP

Board-Level Commitment is Non-Negotiable

ISO 27001:2022 demands active, visible leadership. Top management must not merely sign a policy — they must champion the ISMS, allocate resources, demonstrate understanding of IS risks, and be accountable for ISMS performance. In regulated industries, regulators increasingly examine board-level IS governance directly.

Clause Requirements

- 5.1: Top management must demonstrate leadership and commitment to the ISMS — establish policy, integrate IS into business processes, ensure resources, promote continual improvement
- 5.2: Establish, review and communicate an Information Security Policy aligned to the organisation's context and strategic direction
- 5.3: Assign and communicate ISMS roles, responsibilities and authorities — including a nominated IS function/CISO with board access

Mandatory Documents	Records to Maintain
✓ Information Security Policy (CEO/Board signed) ✓ ISMS Roles, Responsibilities & Authorities Document ✓ RACI Matrix for ISMS functions ✓ IS Governance Charter ✓ Policy communication evidence	✓ Board/exec resolution or mandate establishing ISMS ✓ Policy distribution & acknowledgement records ✓ CISO/ISMS Manager appointment letter ✓ Management review attendance records ✓ Resource allocation approvals

Process Owner & Implementer Actions

- Secure a formal board resolution or executive mandate authorising the ISMS programme with budget allocation
- Draft the Information Security Policy — must include: ISMS scope reference, security objectives, commitment to meet applicable requirements (NDPR, GDPR, CBN IS Framework), commitment to continual improvement
- Appoint a CISO or Information Security Manager with formal authority, defined reporting line and direct board/executive access
- Build the ISMS RACI matrix: assign ownership for risk assessment, SoA, control implementation, internal audit, training, and management review
- Ensure top management is briefed on ISMS performance and material security incidents at minimum quarterly
- Communicate the IS Policy to all staff, contractors and relevant third parties — retain evidence of distribution and acknowledgement

■ **Practitioner Tip:** Certification auditors will interview top management. They must understand the Information Security Policy their accountability for ISMS performance, and the most recent significant security risk or incident. Brief executives before any audit — unprepared leadership is a leading cause of major nonconformities.

6. CLAUSE 6 — PLANNING

Risk Assessment, SoA, Risk Treatment & ISMS Objectives

Clause 6 is the intellectual core of ISO 27001:2022. It requires a rigorous risk assessment process, a formally managed risk treatment plan, a Statement of Applicability (SoA) covering all 93 Annex A controls, and measurable ISMS objectives. The SoA is the document auditors scrutinise most intensively — every control must appear with a clear justification.

6.1 Actions to Address Risks and Opportunities

- 6.1.1: Identify risks and opportunities relevant to the ISMS context that could affect conformance with requirements
- 6.1.2: Define and apply an IS risk assessment process — consistent, valid and comparable results; identify risk owners
- 6.1.3: Define and apply an IS risk treatment process — select controls, produce Statement of Applicability (SoA), obtain risk owner approval
- Note: SoA must list all 93 Annex A controls with justification for inclusion or exclusion — no control may be omitted from the SoA even if excluded from implementation

Document / Record	Content Required	Owner	Review Freq.
Risk Assessment Methodology	Risk identification approach, scoring criteria (likelihood × impact), risk acceptance threshold, owner approval	CISO/Risk Mgr	Annual
Information Asset Register	All in-scope information assets categorised by type, owner, classification, and location	Asset Owners	Annual
Risk Register	All identified risks with scores, existing controls, residual risk, treatment decision, risk owner	CISO	6-monthl y
Statement of Applicability (SoA)	All 93 Annex A controls: included/excluded, justification, implementation status	CISO	Annual
Risk Treatment Plan (RTP)	Selected controls, implementation actions, owners, timelines, resources required	CISO	Quarterly
Risk Assessment Report	Consolidated findings from each assessment cycle — management approved	CISO	Annual

■ **Practitioner Tip:** The SoA is the most scrutinised document in any ISO 27001 audit. Every single one of the 93 Annex A controls must appear. Excluding a control without a documented business justification is a Major Nonconformity. Never omit a control from the SoA — you can exclude it from implementation, but justify it clearly.

6.2 Information Security Objectives

- Establish IS objectives at relevant functions and levels — aligned to the IS Policy
- Objectives must be measurable (quantified or verifiable), monitored, communicated and updated as appropriate
- Determine: what will be done, resources required, responsible persons, completion timeline, how results will be evaluated

Mandatory Documents	Records to Maintain
✓ Information Security Objectives Document	✓ Objectives review and update records
✓ IS Objectives Monitoring Plan	✓ Evidence of objectives communicated
✓ ISMS Change Plan (Clause 6.3)	✓ Change management records

Practitioner Tip: ISMS objectives must be SMART. 'Reduce phishing risk' is not an objective. 'Reduce successful phishing click-through rate from 18% to below 5% by Q4 through simulated phishing training and technical controls' is. Unmeasurable objectives draw Opportunities for Improvement (OFIs) from auditors.

7. CLAUSE 7 — SUPPORT

Competence, Awareness, Communication & Documented Information

Clause 7 provides the people and documentation infrastructure for the ISMS. Without competent personnel, genuine security awareness, structured communication, and a robust document management system, even the best-designed ISMS will fail in practice. Auditors will test all four dimensions and review evidence of training, awareness and document control.

Clause Requirements

- 7.1: Determine and provide the resources necessary for ISMS establishment, implementation, maintenance and improvement
- 7.2: Ensure competence of persons performing ISMS-related work — by education, training or experience; retain evidence
- 7.3: Ensure all personnel are aware of the IS Policy, their contribution to ISMS effectiveness, and implications of non-conformance
- 7.4: Establish internal and external ISMS communication processes — what, when, with whom, how
- 7.5: Create, control and maintain all required documented information — documents and records with access control, version management and retention

Mandatory Documents	Records to Maintain
✓ IS Competency Framework & Training Plan ✓ IS Awareness Programme ✓ ISMS Communication Plan ✓ Document Control Procedure ✓ ISMS Documented Information Register ✓ Records Retention Schedule	✓ Training needs analysis records ✓ Training attendance & completion records ✓ Awareness delivery evidence ✓ Competence assessment results ✓ Document review & approval records ✓ Communication activity logs

Process Owner & Implementer Actions

- Conduct an IS Training Needs Analysis (TNA) for all roles identified in the ISMS RACI matrix
- Deliver role-specific IS training: CISO (ISO 27001 Lead Implementer), IS Team (technical controls, incident response), all staff (awareness), IT team (technical controls), developers (secure coding)
- Deliver annual IS awareness training covering: IS Policy, phishing recognition, password security, incident reporting, clean desk/screen, acceptable use
- Implement phishing simulation exercises at minimum twice per year with targeted remedial training for those who fail
- Establish a Document Management System (DMS) with version control, access permissions, and retention rules
- Create a ISMS Communication Plan — include regulatory notification protocols
- Set retention periods: risk assessments and SoA — 5 years; audit reports — 3 years; incident records — 5 years; training records — 3 years

8. CLAUSE 8 — OPERATION

Executing the ISMS: Risk Treatment, Controls & Operational Procedures

Clause 8 governs the operational execution of the ISMS. It requires that all planned processes are implemented and controlled, risk assessments are performed at planned intervals, and the risk treatment plan is executed with evidence retained. This is where documented policies become active security controls — and where the gap between 'ISMS on paper' and 'ISMS in practice' is most visible to auditors.

Clause Requirements

- 8.1: Plan, implement and control all processes needed to meet ISMS requirements; manage externally provided processes; control planned changes; review unintended changes
- 8.2: Perform IS risk assessments at planned intervals — at minimum annually and when significant changes occur; retain documented results
- 8.3: Implement the IS risk treatment plan; retain evidence of results; Annex A control implementation must be evidenced

Mandatory Documents	Records to Maintain
✓ Operational Security Procedures (for all critical IS processes) ✓ Supplier & Third-Party Security Policy ✓ Change Management Procedure with IS review gates ✓ Incident Response Plan & Procedure ✓ Business Continuity Plan (IS aspects — links to ISO 22301)	✓ Risk assessment results (each cycle) ✓ Risk treatment implementation evidence (configs, tickets, sign-offs) ✓ Supplier security assessment records ✓ Operational procedure review records ✓ Change request logs and approvals ✓ Incident log records

Process Owner & Implementer Actions

- Implement all controls selected in the Risk Treatment Plan with documented configuration evidence
 - Conduct IS risk assessments at minimum annually and whenever significant business, technology or threat landscape changes occur
 - Establish a formal change management process with mandatory IS review gate before production deployment
 - Implement a supplier onboarding security assessment process — evaluate all critical suppliers against IS requirements before engagement
 - Document all critical IS operational procedures: access provisioning/deprovisioning, patch management, backup verification, incident triage, privileged access management
 - Maintain a supplier register with IS assessment status, contract IS clauses, and review dates
 - Retain evidence of control implementation — screenshots, configuration exports, policy acknowledgements, test results
- **Practitioner Tip:** Operational evidence is everything. 'We have a policy' is not sufficient — auditors expect to see evidence that controls are actually implemented and operating effectively. Maintain implementation evidence for every Annex A control: logs, configurations, reports, and test results.

9. CLAUSE 9 — PERFORMANCE EVALUATION

Monitoring, Internal Audit & Management Review

Clause 9 requires systematic monitoring of ISMS effectiveness, independent internal auditing, and formal management review. This is where the organisation proves that its ISMS is not just documented but actually working. The management review format changed in ISO 27001:2022 — Clause 9.3 is now structured into three sub-clauses with specific mandatory inputs and outputs.

Clause Requirements

- 9.1: Monitor, measure, analyse and evaluate IS performance — determine what, how and when to measure; retain documented results
- 9.2.1/9.2.2: Conduct internal ISMS audits at planned intervals — auditors must not audit their own areas; programme must consider importance of processes and results of previous audits
- 9.3.1: Top management reviews ISMS at planned intervals — general framework
- 9.3.2: Management review inputs: IS performance, risk treatment status, audit results, nonconformities, interested party feedback, changes in context, improvement opportunities
- 9.3.3: Management review results — decisions on improvement opportunities, ISMS changes, resource needs

Mandatory Documents	Records to Maintain
✓ ISMS Monitoring & Measurement Framework ✓ Internal Audit Programme ✓ Internal Audit Procedure ✓ Management Review Agenda Template ✓ ISMS Performance Dashboard / Scorecard	✓ Internal audit reports and nonconformities ✓ Corrective action records ✓ Management review minutes ✓ KPI measurement reports (monthly/quarterly) ✓ Audit programme completion records

Process Owner & Implementer Actions

- Define 10–15 measurable ISMS KPIs with targets, measurement frequency and data sources (see Section 16)
- Build an annual internal audit programme covering all ISO 27001:2022 clauses and Annex A control domains
- Train and qualify internal auditors — or engage qualified external ISMS auditors for objectivity
- Produce a formal Management Review Report after each review meeting covering all mandatory 9.3.2 inputs
- Ensure management review outputs (9.3.3) include documented decisions on improvement opportunities, resource allocation, and ISMS changes
- Report ISMS performance dashboard to board or executive committee at minimum quarterly

■ **Practitioner Tip:** Management review minutes must explicitly address all 9.3.2 mandatory inputs and produce the required 9.3.3 outputs. A meeting without minutes is not a management review. A meeting with generic minutes covering only headline numbers will draw an auditor's attention to what was missing.

10. CLAUSE 10 — IMPROVEMENT

Nonconformity, Corrective Action & Continual Improvement

Clause 10 closes the PDCA loop. Every nonconformity — whether from an audit, incident, exercise or external report — must be formally investigated, corrected at root cause level, and verified for effectiveness. ISO 27001:2022 expects a living ISMS culture of improvement, not a system frozen at certification date.

Clause Requirements

- 10.1: Continually improve the suitability, adequacy and effectiveness of the ISMS — an ongoing, systematic obligation
- 10.2: React to nonconformities — take action to correct, investigate root cause, evaluate similar risks, implement corrective action, verify effectiveness, update ISMS if necessary

Records to Maintain	
Mandatory Documents	
✓ Nonconformity & Corrective Action Procedure	✓ Nonconformity records with root cause analysis
✓ ISMS Continual Improvement Plan	✓ Corrective action log with closure evidence
✓ Lessons Learned Register	✓ Post-incident review reports
✓ Post-Incident Review Template	✓ Updated documents following corrective actions
	✓ Evidence of ISMS improvements

Process Owner & Implementer Actions

- Establish a formal nonconformity reporting and tracking system — NCR forms or integrated ticketing tool
- Conduct root cause analysis (RCA) for every significant nonconformity — fix the systemic cause, not only the symptom
- Verify corrective action effectiveness before formally closing NCRs — a recurring issue is an open nonconformity
- Conduct post-incident reviews after every significant IS incident — complete within 10 business days
- Maintain a live Lessons Learned Register — feed findings from incidents, audits and exercises into actionable ISMS improvements
- Ensure all improvements are reflected in updated documents, risk register, SoA and operational procedures

■ **Practitioner Tip:** The auditor wants evidence of a culture of learning. Open NCRs are acceptable — having none is suspicious. Having no corrective action mechanism, or NCRs that never close, is a Major Nonconformity. Document everything, close everything, and show the evidence.

11. ANNEX A — ORGANISATIONAL CONTROLS (5.1–5.37)

37 Controls | Theme 1 of 4

Organisational controls address governance, policies, risk management, supplier security, incident management, and legal compliance. They form the governance backbone of the ISMS — without strong organisational controls, technical controls will be undermined by poor governance.

Ref	Control Name	Purpose	Mandatory Document / Record
5.1	Policies for information security	Define IS policies approved by management	IS Policy Suite + version history
5.2	IS roles and responsibilities	Assign IS responsibilities to defined roles	RACI Matrix + appointment records
5.3	Segregation of duties	Prevent fraud/error by splitting conflicting tasks	SoD Matrix + access review records
5.4	Management responsibilities	Managers ensure staff follow IS policies	Policy acknowledgement records
5.5	Contact with authorities	Maintain contacts with law enforcement, regulators	Contacts Register (NDPC, NITDA, Police, CERT) + contact logs
5.6	Contact with special interest groups	Engage IS forums, ISACs, threat sharing groups	Membership/participation register
5.7	Threat intelligence (NEW)	Collect and act on threat intelligence	Threat Intelligence Policy + threat reports + response logs
5.8	IS in project management	Embed IS requirements in all projects	IS in Project Procedure + project risk assessments
5.9	Inventory of information assets	Maintain complete, accurate asset inventory	Information Asset Register (systems, data, people, premises)
5.10	Acceptable use of information assets	Define acceptable use for all asset types	Acceptable Use Policy (AUP) + signed acknowledgements
5.11	Return of assets	Ensure assets returned on employment/contract end	Asset Return Procedure + Exit Checklist + return receipts
5.12	Classification of information	Classify by sensitivity and criticality	Information Classification Policy + scheme (e.g., Public/Internal/Confidential/Secret)
5.13	Labelling of information	Apply classification labels	Labelling Procedure + labelled document samples
5.14	Information transfer	Protect information transferred internally/externally	Information Transfer Policy + NDAs + data sharing agreements
5.15	Access control	Control access based on business need	Access Control Policy + access matrix

Ref	Control Name	Purpose	Mandatory Document / Record
5.16	Identity management	Manage full identity lifecycle	Identity Management Procedure + provisioning/deprovisioning logs
5.17	Authentication information	Secure management of credentials	Password Policy + MFA enrolment records
5.18	Access rights	Grant, review, modify and revoke access rights	Access Management Procedure + quarterly review records
5.19	IS in supplier relationships	Manage IS risks from suppliers	Supplier Security Policy + supplier risk register
5.20	IS in supplier agreements	Include IS requirements in contracts	Supplier Contract IS Clauses + signed contracts
5.21	IS in ICT supply chain	Address IS across ICT supply chain	ICT Supply Chain Security Policy + software provenance records
5.22	Monitoring of supplier services	Review supplier IS performance regularly	Supplier Review Procedure + review reports
5.23	IS for cloud services (NEW)	Govern security of cloud acquisition and use	Cloud Security Policy + cloud vendor assessments + CSP contracts
5.24	IS incident management planning	Prepare for IS incident response	Incident Management Policy + Incident Response Plan
5.25	Assessment of IS events	Classify and assess security events	Incident Classification Matrix + event triage records
5.26	Response to IS incidents	Coordinate response to incidents	Incident Response Procedures + incident reports
5.27	Learning from IS incidents	Use incidents to improve controls	Post-Incident Review Template + lessons learned log
5.28	Collection of evidence	Preserve evidence for legal/disciplinary use	Digital Forensics Procedure + chain of custody records
5.29	IS during disruption	Maintain IS during adverse events	BCP IS Continuity Plan + continuity review records
5.30	ICT readiness for BC (NEW)	Ensure ICT supports business continuity	ICT Continuity Plan + RTO/RPO documentation + DR test records
5.31	Legal, statutory, regulatory requirements	Identify and comply with all applicable requirements	Legal & Regulatory Register + compliance calendar + assessments
5.32	Intellectual property rights	Protect IP; manage software licences	IPR Policy + software licence register + audit records
5.33	Protection of records	Protect records from loss, falsification, destruction	Records Management Policy + Retention Schedule + disposal certificates
5.34	Privacy and PII protection	Protect personal data per applicable law	Privacy Policy + PII Register + DPIA process + data subject request log

Ref	Control Name	Purpose	Mandatory Document / Record
5.35	Independent review of IS	Conduct independent ISMS reviews	Internal Audit Procedure + third-party review schedule + audit reports
5.36	Compliance with IS policies	Monitor and ensure IS policy compliance	Compliance Monitoring Procedure + compliance reports
5.37	Documented operating procedures	Document procedures for IT/IS operations	IT Operations Manual + operational procedures library

12. ANNEX A — PEOPLE CONTROLS (6.1–6.8)

8 Controls | Theme 2 of 4

People controls address the human element — pre-employment screening, employment terms, security training, disciplinary processes, and responsibilities after termination. The human factor remains the leading cause of security breaches; these controls are essential safeguards.

Ref	Control Name	Purpose	Mandatory Document / Record
6.1	Screening	Screen employees and contractors before employment	HR Screening Policy + background check records + DBS results
6.2	Terms and conditions of employment	IS obligations in employment contracts	Employment Contract IS Clauses + signed NDA records
6.3	IS awareness, education and training	Deliver ongoing IS training to all staff	IS Awareness Programme + training records + assessment scores
6.4	Disciplinary process	Enforce consequences for IS policy violations	Disciplinary Policy with IS provisions + disciplinary records
6.5	Responsibilities after termination	Maintain IS obligations post-employment	Exit Policy + Exit Checklist + account closure logs + asset return records
6.6	Confidentiality/non-disclosure agreements	Protect confidential information via NDAs	NDA Templates (staff, supplier, visitor) + signed NDAs + renewal records
6.7	Remote working	Secure remote work environments	Remote Working Policy + remote IS risk assessments + VPN/MDM records
6.8	IS event reporting	Enable staff to report IS events	Incident Reporting Procedure + reporting channels + event/incident reports

13. ANNEX A — PHYSICAL CONTROLS (7.1–7.14)

14 Controls | Theme 3 of 4

Physical controls protect the organisation's premises, equipment, and the people who work within them. Physical security breaches — whether by outsiders or insiders — can be as damaging as cyber attacks. A strong digital security posture must be matched by commensurate physical controls.

Ref	Control Name	Purpose	Mandatory Document / Record
7.1	Physical security perimeters	Define and secure physical boundaries	Physical Security Policy + Secure Area Map + perimeter inspection records
7.2	Physical entry	Control physical access to secure areas	Physical Access Control Procedure + access logs + visitor registers + badge records
7.3	Securing offices, rooms and facilities	Protect offices from unauthorised access	Facility Security Plan + physical security inspection reports
7.4	Physical security monitoring (NEW)	Monitor physical premises to detect threats	CCTV/monitoring policy + camera placement map + footage retention logs
7.5	Protecting against physical/environmental threats	Protect against fire, flood, power failure	Environmental Risk Assessment + Facilities Management Plan + monitoring logs
7.6	Working in secure areas	Define rules for working in restricted areas	Secure Area Working Rules + access logs + authorisation records
7.7	Clear desk and clear screen	Minimise risk from unsecured information	Clear Desk & Clear Screen Policy + compliance audit records
7.8	Equipment siting and protection	Site equipment to minimise threats	Asset Placement Guidelines + equipment inventory + site inspection records
7.9	Security of assets off-premises	Protect assets outside secure areas	Off-Site Asset Use Policy + asset loan records + device tracking logs
7.10	Storage media	Manage, use, transport and dispose of media	Storage Media Management Procedure + media inventory + destruction certificates
7.11	Supporting utilities	Protect against power failure, HVAC failure	Utilities Risk Assessment + UPS/generator maintenance plan + maintenance logs
7.12	Cabling security	Protect power and data cabling	Cabling Security Guidelines + Network Diagram + cable inspection records

Ref	Control Name	Purpose	Mandatory Document / Record
7.13	Equipment maintenance	Maintain equipment for availability and integrity	Equipment Maintenance Schedule + maintenance records + vendor service reports
7.14	Secure disposal or re-use of equipment	Sanitise/destroy equipment before disposal	Equipment Disposal Procedure + Data Destruction Standard + disposal certificates

14. ANNEX A — TECHNOLOGICAL CONTROLS (8.1–8.34)

34 Controls | Theme 4 of 4

Technological controls cover the full spectrum of technical IS safeguards — from endpoint security and access management to secure development, cryptography, vulnerability management and the 8 new technological controls introduced in 2022. These controls require technical implementation evidence for certification.

Ref	Control Name	Purpose	Mandatory Document / Record
8.1	User endpoint devices	Protect information on endpoint devices	Endpoint Security Policy + MDM config + device inventory + patch logs
8.2	Privileged access rights	Restrict and control privileged access	PAM Policy + privileged account register + quarterly PAM review records
8.3	Information access restriction	Restrict access per access control policy	Access Control Policy + Role-Based Access Matrix + access review records
8.4	Access to source code	Control access to source code	Source Code Access Policy + repository access logs + developer access reviews
8.5	Secure authentication	Implement strong authentication	Authentication Policy + MFA enrolment records + failed login monitoring
8.6	Capacity management	Monitor and manage resource capacity	Capacity Management Plan + capacity monitoring reports + threshold alert records
8.7	Protection against malware	Implement anti-malware controls	Malware Protection Policy + AV/EDR deployment + detection logs + outbreak records
8.8	Management of technical vulnerabilities	Identify and remediate vulnerabilities	Vulnerability Management Procedure + Patch Management Policy + scan reports + patch compliance
8.9	Configuration management (NEW)	Manage secure configurations	Configuration Management Policy + Baseline Config Standards + drift detection logs
8.10	Information deletion (NEW)	Delete information when no longer needed	Data Deletion & Retention Policy + deletion logs + retention compliance records
8.11	Data masking (NEW)	Apply masking/pseudonymisation where appropriate	Data Masking Policy & Technical Standard + implementation records + test evidence
8.12	Data leakage prevention (NEW)	Detect and prevent unauthorised data exfiltration	DLP Policy + DLP tool configuration + DLP alerts + investigation records

Ref	Control Name	Purpose	Mandatory Document / Record
8.13	Information backup	Backup information to ensure recovery	Backup Policy + Backup Schedule + completion logs + restore test records
8.14	Redundancy of information processing	Ensure system resilience and availability	HA/Redundancy Design Document + DR Plan + failover test records + uptime reports
8.15	Logging	Implement audit logging across systems	Logging Policy + Log Management Procedure + system/security logs + log review records
8.16	Monitoring activities (NEW)	Monitor networks and systems for anomalies	Security Monitoring Policy + SIEM/SOC runbooks + alert records + anomaly investigation records
8.17	Clock synchronisation	Synchronise system clocks to reliable source	NTP Configuration Standard + clock sync audit records
8.18	Use of privileged utility programs	Control tools that can bypass IS controls	Privileged Utilities Register + Usage Policy + usage logs + authorisation records
8.19	Installation of software on operational systems	Control software installed in production	Software Installation Policy + authorised software list + change records
8.20	Networks security	Manage and control network security	Network Security Policy + Network Architecture Diagram + access logs + firewall review
8.21	Security of network services	Secure network services	Network Services Security Agreement + SLA reviews + security assessment records
8.22	Segregation of networks	Segregate sensitive network segments	Network Segmentation Design + audit records + VLAN configuration evidence
8.23	Web filtering (NEW)	Filter web access to block malicious content	Web Filtering Policy + proxy/filter configuration + web filter logs + incident records
8.24	Use of cryptography	Apply cryptographic controls	Cryptography Policy + Key Management Procedure + encryption records + key management logs
8.25	Secure development lifecycle	Integrate security into development phases	Secure SDLC Policy + Security Design Review Checklist + code review records
8.26	Application security requirements	Define IS requirements for applications	Application Security Standard + security requirements documentation + acceptance test records

Ref	Control Name	Purpose	Mandatory Document / Record
8.27	Secure system architecture and engineering	Apply security engineering principles	Security Architecture Principles Document + architecture review records
8.28	Secure coding (NEW)	Apply secure coding standards	Secure Coding Standard (OWASP-aligned) + code review records + SAST/DAST scan results
8.29	Security testing in dev and acceptance	Conduct security testing before release	Security Testing Policy + Pen Test Procedure + security test reports + defect remediation records
8.30	Outsourced development	Govern security in outsourced development	Outsourced Development Security Policy + vendor code review + acceptance test evidence
8.31	Separation of dev, test and production	Separate environments to reduce risk	Environment Separation Policy + pipeline config + environment access logs
8.32	Change management	Control changes to information systems	Change Management Procedure with IS gates + change request logs + approvals
8.33	Test information	Protect information used in testing	Test Data Management Policy + test data sanitisation records + test access logs
8.34	Protection of IS during audit testing	Protect systems during audit/test activities	Audit Testing Rules of Engagement + test authorisation records + activity logs

15. MASTER DOCUMENTS & RECORDS REGISTER

Complete Checklist for ISO 27001:2022 Certification

The following consolidated register covers all mandatory and recommended documents and records required for ISO 27001:2022 certification. Every item must be documented, version-controlled, appropriately approved and accessible. Cross-reference with your SoA for Annex A control evidence requirements.

#	Document / Record	ISO 27001:2022 Clause	Owner	Review Freq.
1	ISMS Scope Document	4.3	CISO	Annual
2	Context of Organisation Analysis (PESTLE/SWOT)	4.1	CISO	Annual
3	Interested Parties Register	4.2	CISO	Annual
4	Legal & Regulatory Obligations Register	4.2	Legal / CISO	Annual
5	Information Security Policy	5.2	CEO / Board	Annual
6	ISMS Roles, Responsibilities & RACI Matrix	5.3	HR / CISO	Annual
7	IS Governance Charter / CISO Appointment	5.3	Board	Annual
8	Risk Assessment Methodology	6.1.2	CISO / Risk Mgr	Annual
9	Information Asset Register	6.1.2 / A.5.9	Asset Owners	6-monthly
10	Risk Register	6.1.2	CISO	6-monthly
11	Statement of Applicability (SoA)	6.1.3	CISO	Annual
12	Risk Treatment Plan (RTP)	6.1.3	CISO	Quarterly
13	Risk Assessment Report	6.1.2	CISO	Annual
14	Information Security Objectives Document	6.2	CISO	Annual
15	ISMS Change Plan	6.3	CISO	Ongoing
16	IS Competency Framework & Training Plan	7.2	HR / CISO	Annual
17	IS Awareness Programme	7.3	CISO / HR	Annual
18	ISMS Communication Plan	7.4	Comms / CISO	Annual
19	Document Control Procedure	7.5	CISO	Annual
20	ISMS Documented Information Register	7.5	CISO	Ongoing
21	Records Retention Schedule	7.5	Records / CISO	Annual
22	Training & Competence Records	7.2	HR	Ongoing
23	Phishing Simulation Reports	7.3	CISO	Per simulation
24	Operational Security Procedures	8.1	CISO / IT Mgr	Annual

#	Document / Record	ISO 27001:2022 Clause	Owner	Review Freq.
25	Supplier Security Policy	8.1 / A.5.19	Procurement / CISO	Annual
26	Change Management Procedure	8.1 / A.8.32	IT / CISO	Annual
27	Incident Response Plan & Procedures	8.1 / A.5.24	CISO / SOC	Annual
28	Risk Assessment Results (per cycle)	8.2	CISO	Annual
29	Risk Treatment Implementation Evidence	8.3	CISO / IT	Per control
30	Supplier Register & Assessment Records	8.1 / A.5.22	Procurement	Annual
31	ISMS Monitoring & Measurement Framework	9.1	CISO	Annual
32	ISMS KPI / Performance Dashboard	9.1	CISO	Monthly
33	Internal Audit Programme	9.2	Internal Audit	Annual
34	Internal Audit Reports	9.2	Internal Audit	Per audit
35	Management Review Minutes	9.3	Board Sec. / CISO	Per review
36	Nonconformity & Corrective Action Procedure	10.2	CISO	Annual
37	Corrective Action Log	10.2	CISO	Ongoing
38	Post-Incident Review Reports	10.1 / A.5.27	CISO / SOC	Per incident
39	Lessons Learned Register	10.1	CISO	Ongoing
40	ISMS Continual Improvement Plan	10.1	CISO	Annual
41	Information Classification Policy & Scheme	A.5.12	CISO	Annual
42	Access Control Policy	A.5.15	IT Security / CISO	Annual
43	Password & Authentication Policy	A.5.17 / A.8.5	IT Security	Annual
44	Acceptable Use Policy (AUP)	A.5.10	CISO / HR	Annual
45	Remote Working Policy	A.6.7	IT / HR / CISO	Annual
46	Cryptography Policy & Key Management Procedure	A.8.24	IT Security	Annual
47	Network Security Policy	A.8.20–8.22	Network / CISO	Annual
48	Vulnerability Management Procedure	A.8.8	IT Security	Annual
49	Patch Management Policy	A.8.8	IT Operations	Annual
50	Secure SDLC Policy	A.8.25–8.29	Dev / CISO	Annual
51	Secure Coding Standard (OWASP-aligned)	A.8.28	Dev / CISO	Annual
52	DLP Policy & Configuration	A.8.12	IT Security	Annual
53	Cloud Security Policy	A.5.23	IT / CISO	Annual
54	Threat Intelligence Policy & Reports	A.5.7	CISO / SOC	Monthly
55	Privacy Policy & PII Processing Register	A.5.34	DPO / CISO	Annual

#	Document / Record	ISO 27001:2022 Clause	Owner	Review Freq.
56	Backup Policy & Restore Test Records	A.8.13	IT Operations	Annual
57	Physical Security Policy	A.7.1–7.14	Facilities / CISO	Annual
58	Equipment Disposal Procedure & Records	A.7.14	IT / Facilities	Per disposal
59	Configuration Baseline Standards	A.8.9	IT Operations	Annual
60	Web Filtering Policy & Logs	A.8.23	IT Security	Annual

16. KEY ISMS METRICS & KPIs

Measuring ISMS Effectiveness — ISO 27001 Clause 9.1

Effective ISMS programmes are measured, not assumed. The following KPIs align to ISO 27001:2022 Clause 9.1 and must be reported to management regularly. Build an ISMS performance dashboard that tracks these metrics and presents them to the board quarterly.

KPI	Description	Target	Frequency
Risk Register Coverage	% of information assets with completed risk assessment	100%	Annual
SoA Currency	All 93 Annex A controls documented with current justification	100%	Annual
Risk Treatment Completion	% of RTP actions completed within agreed timelines	>90%	Quarterly
Patch Compliance Rate	% of critical systems patched within SLA (e.g., critical 72hr, high 7 days)	>95%	Monthly
Vulnerability Scan Coverage	% of in-scope systems scanned for vulnerabilities monthly	100%	Monthly
Critical Vulnerabilities Open >30 days	Number of critical/high vulnerabilities unresolved beyond SLA	0 critical	Monthly
MFA Adoption Rate	% of all user accounts with MFA enabled	100%	Monthly
Phishing Simulation Click Rate	% of staff who click simulated phishing links (trend reduction)	<5%	Bi-annual
IS Awareness Completion	% of all staff completing annual IS awareness training	100%	Annual
Incident Mean Time to Detect (MTTD)	Average time from incident occurrence to detection	Trending down	Monthly
Incident Mean Time to Respond (MTTR)	Average time from detection to incident containment	Trending down	Per incident
IS Incidents per Quarter	Number of confirmed IS incidents (trend monitoring)	Trend	Quarterly
Privileged Account Review Completion	% of privileged accounts reviewed within review cycle	100%	Quarterly
Supplier IS Assessment Coverage	% of critical suppliers with current IS assessment	100%	Annual
Internal Audit NCR Closure Rate	% of audit nonconformities closed within agreed timescales	>90%	Quarterly
Document Currency Rate	% of ISMS documents reviewed within their defined review period	100%	Quarterly
Backup Restore Test Success Rate	% of backup restore tests completed successfully	100%	Quarterly

17. CERTIFICATION ROADMAP

A Structured Pathway to ISO 27001:2022 Certification

A structured ISO 27001:2022 implementation for a mid-size organisation typically takes 9–15 months depending on existing IS maturity, organisational complexity, and resource availability. Each phase must be completed before the next — skipping the risk assessment phase to move quickly to documentation is the most common cause of implementation failure.

Phase	Timeline	Key Activities	Milestone / Deliverable
Phase 1 Foundation & Context	Month 1–2	Secure board mandate · Appoint CISO/ISO · Define ISMS scope · Gap assessment vs ISO 27001:2022 · Context analysis (PESTLE/SWOT) · Interested parties register · Legal & regulatory obligations register	ISMS Scope approved Gap report issued Mandate in place
Phase 2 Leadership & Planning	Month 2–3	Draft & obtain CEO sign-off on IS Policy · Build ISMS RACI matrix · Define IS objectives · Establish document control system · Develop ISMS Communications Plan	IS Policy CEO-signed Objectives documented DMS live
Phase 3 Risk Assessment & SoA	Month 3–5	Build information asset register · Design risk assessment methodology · Conduct risk assessment workshops · Score all risks · Draft Statement of Applicability (SoA v1.0) · Identify control gaps · Obtain management sign-off	Asset Register complete Risk Register baselined SoA v1.0 approved
Phase 4 Control Implementation	Month 5–9	Develop all Annex A mandatory policies · Implement technical controls (MFA, DLP, SIEM, patch mgmt, vulnerability scanning, encryption, access controls) · Implement physical controls · Supplier assessments · Secure SDLC setup	All priority controls implemented Policy suite published Technical controls evidenced
Phase 5 Awareness & Training	Month 8–10	Deliver IS awareness to all staff · Conduct phishing simulations · Deliver IS role-specific training · Document training records	100% awareness delivery Phishing baseline measured Training records on file
Phase 6 Internal Audit & Review	Month 10–13	Conduct internal ISMS audit covering all ISO 27001:2022 clauses and Annex A domains · Address all nonconformities · Conduct management review · Close corrective actions · Update SoA · Final document review	Internal audit complete All NCRs closed Management review minuted SoA finalised

Phase	Timeline	Key Activities	Milestone / Deliverable
Phase 7 Certification Audit	Month 13–15	Stage 1 audit (document & SoA review by certification body) · Address Stage 1 findings · Stage 2 audit (implementation evidence, staff interviews, technical verification) · Address Stage 2 findings · Certification decision	ISO 27001:2022 Certificate Issued

Critical Success Factors

Critical Success Factor	Why It Matters
Board-Level Commitment	Without executive sponsorship and budget, ISMS programmes stall. The board must understand IS risk in business terms.
Realistic, Evidence-Based Risk Assessment	A paper risk assessment that doesn't reflect reality produces a SoA that doesn't protect the organisation. Involve technical staff.
Complete Statement of Applicability	Every one of the 93 controls must appear in the SoA. Missing controls or unjustified exclusions are Major Nonconformities.
Technical Control Implementation Evidence	Policies alone are not sufficient. Auditors verify that controls are actually configured and operating. Retain evidence of everything.
Cross-Functional Ownership	IS is not IT's job alone. HR, Legal, Finance, Operations and Procurement all own Annex A controls that must be evidenced.
Continuous Awareness & Phishing Testing	Human error causes most breaches. Phishing simulations with remedial training are the single highest-ROI IS investment.
Regulatory Alignment	Nigerian (NDPC, CBN, NITDA) and international (GDPR, NIS2, DORA, PCI-DSS) regulatory requirements must be mapped into the SoA and controls.

ABOUT

Toolbox Management Systems Limited

Toolbox Management Systems Limited is a specialist ISO management systems consultancy with deep, hands-on experience in the design, deployment, implementation and certification of internationally recognised management system standards across multiple industries and geographies.

We partner with organisations from the very first clause to the certification handshake — guiding leadership, process owners, IT teams and implementation managers through every requirement, every document, every control, and every audit milestone with precision and practical expertise.

IMPLEMENTATION CONSULTING	CERTIFICATION SUPPORT
We partner with organisations to design, deploy and implement ISO management systems from the ground up — guiding every clause, every document and every certification milestone.	We prepare organisations for third-party certification audits through gap assessments, mock audits and readiness reviews designed to maximise first-time pass rates.
ISO TRAINING	CONTINUAL IMPROVEMENT
We deliver Lead Implementer, Internal Auditor and Awareness training programmes — equipping your team to own and sustain the ISMS long after certification.	We provide ongoing ISMS support, surveillance audit preparation, and management system optimisation to help organisations mature beyond initial certification.

Management System Standards We Deploy

ISO 27001:2022	ISO 22301:2019	ISO 9001:2015	ISO 14001:2015
ISO 45001:2018	ISO 31000:2018	ISO 20000-1:2018	ISO 37001:2016

We help organisations not just achieve certification — but build management systems that deliver real security, real resilience, and real business value.

www.toolboxqhse.com | info@toolboxqhse.com